

Assessing Common Attack Vectors (4e)

Fundamentals of Information Systems Security, Fourth Edition - Lab 06

Student:

Hassinullah Niazy

Email:

niazy27@up.edu

Time on Task:

4 hours, 20 minutes

Progress:

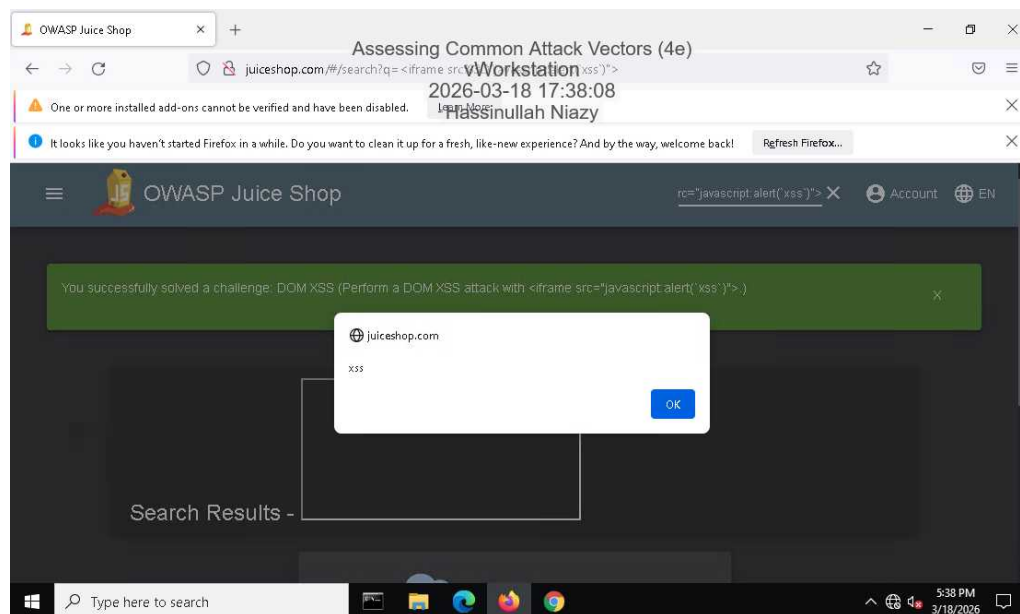
100%

Report Generated: Wednesday, March 25, 2026 at 12:14 AM

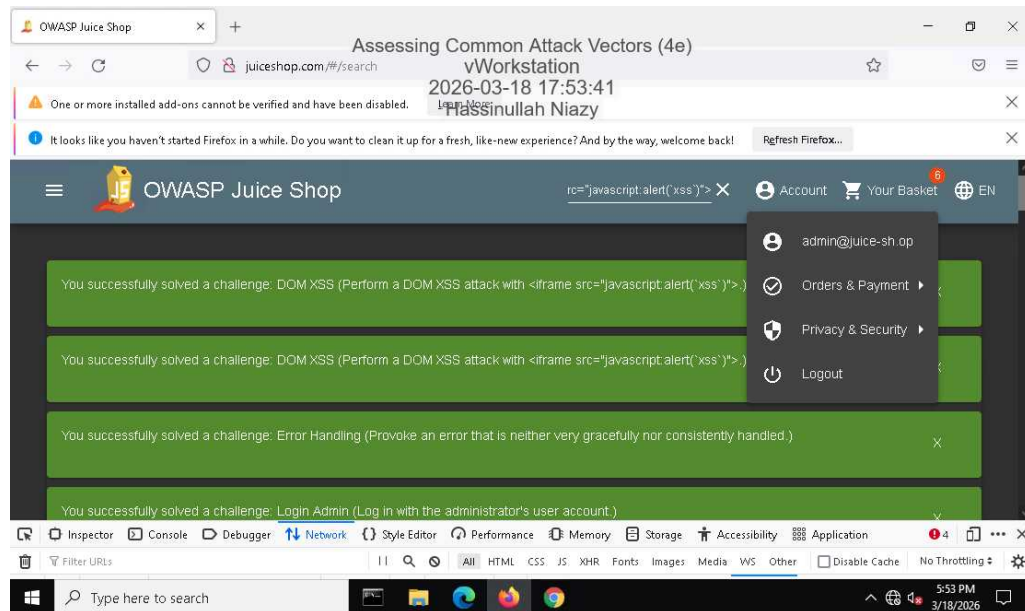
Section 1: Hands-On Demonstration

Part 1: Perform an Injection Attack

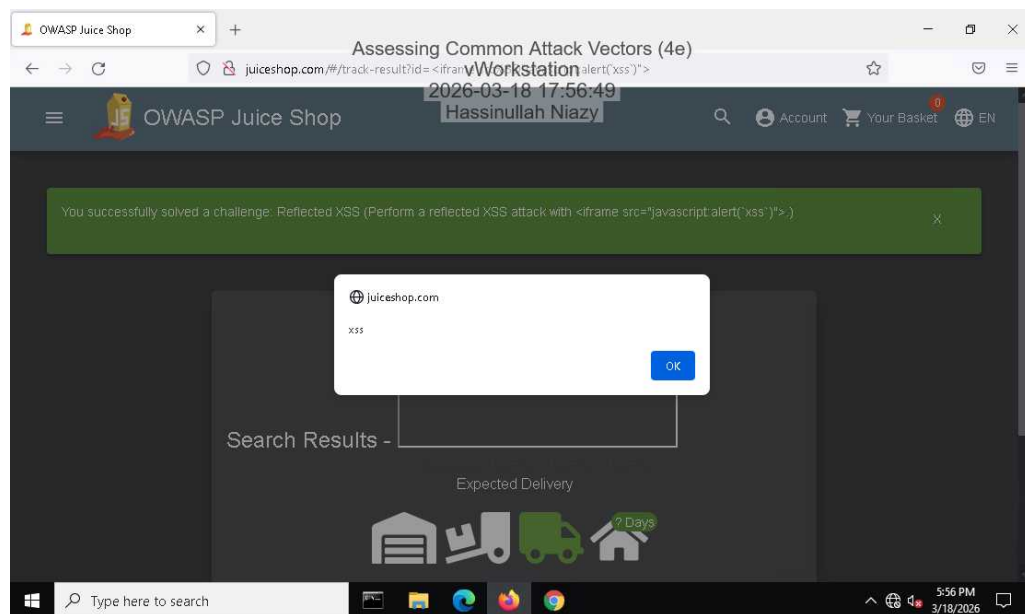
11. Make a screen capture showing the **DOM XSS** dialog box.



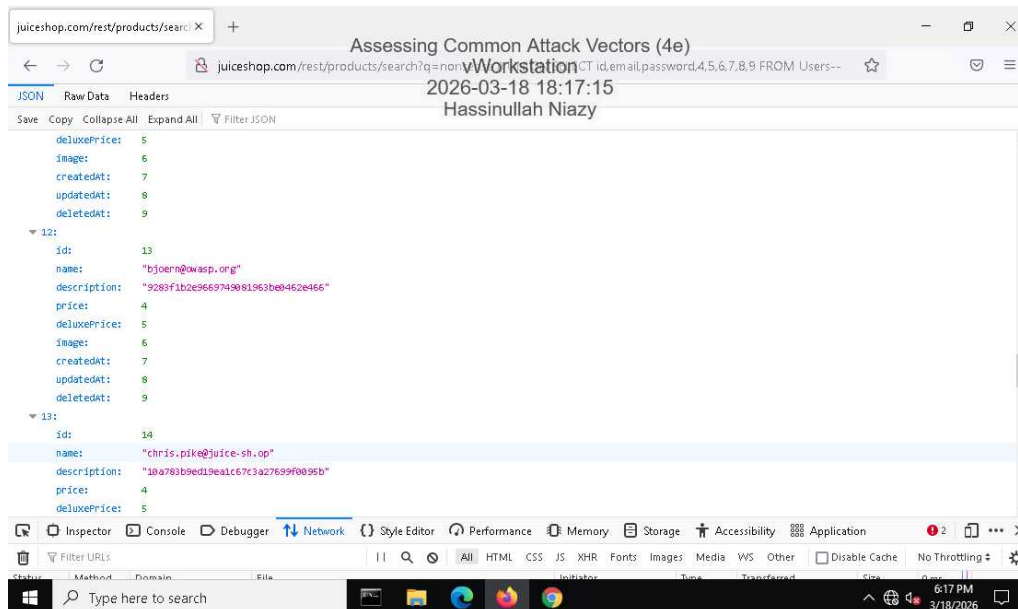
21. Make a screen capture showing the successful admin login.



26. Make a screen capture showing the successful Reflected XSS injection.

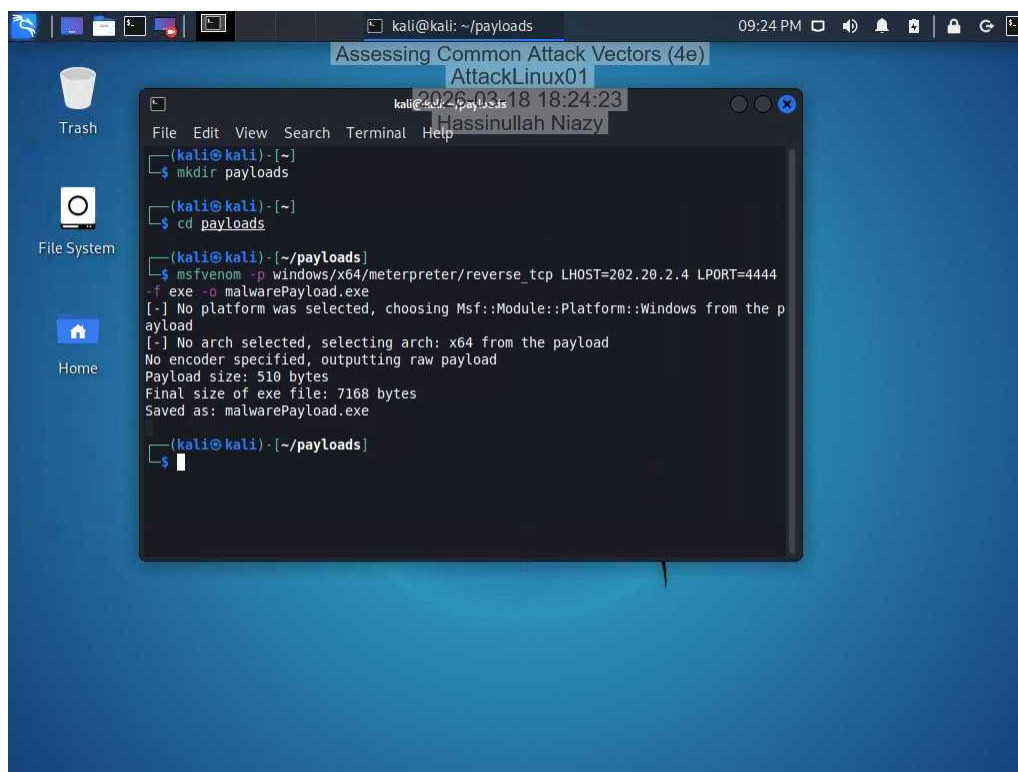


42. Make a screen capture showing the user with the @owasp.org email.

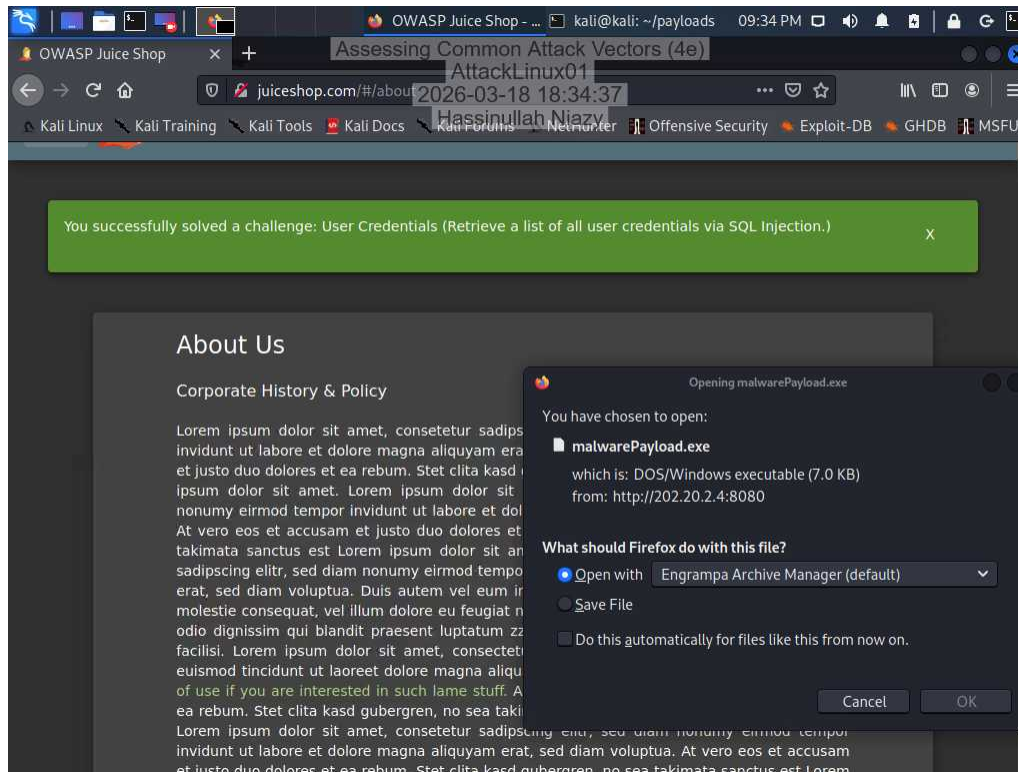


Part 2: Perform a Malware Attack

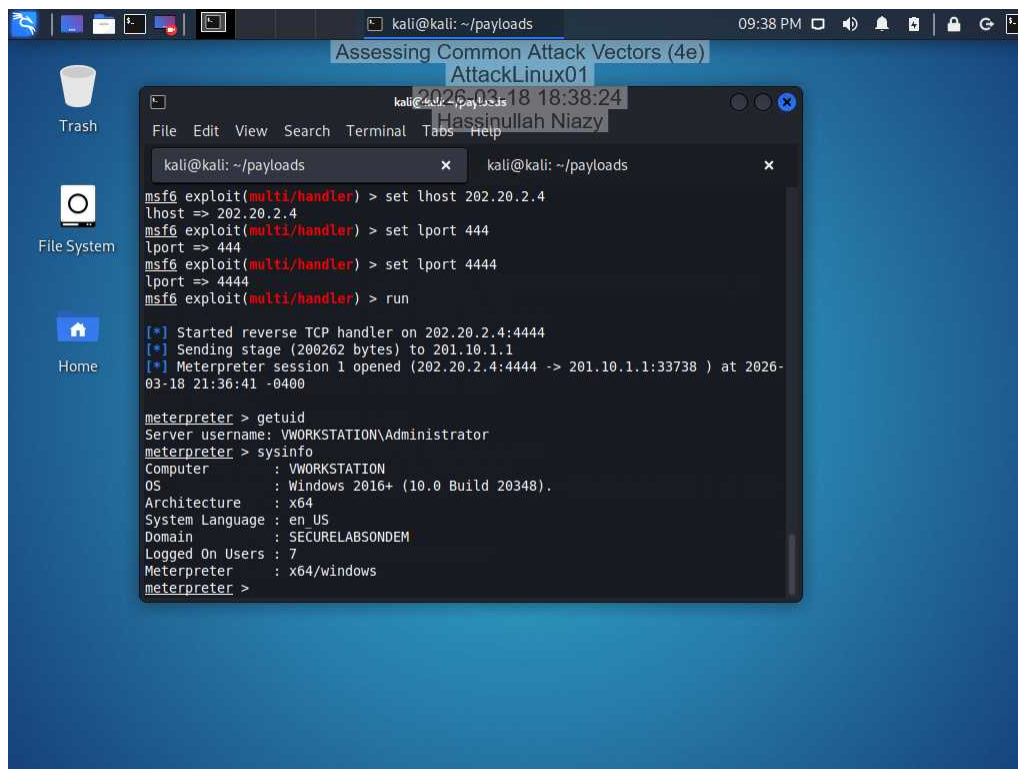
6. Make a screen capture showing the msfvenom output.



23. Make a screen capture showing the Opening malwarePayload.exe dialog box.



36. Make a screen capture showing the output of the sysinfo command.



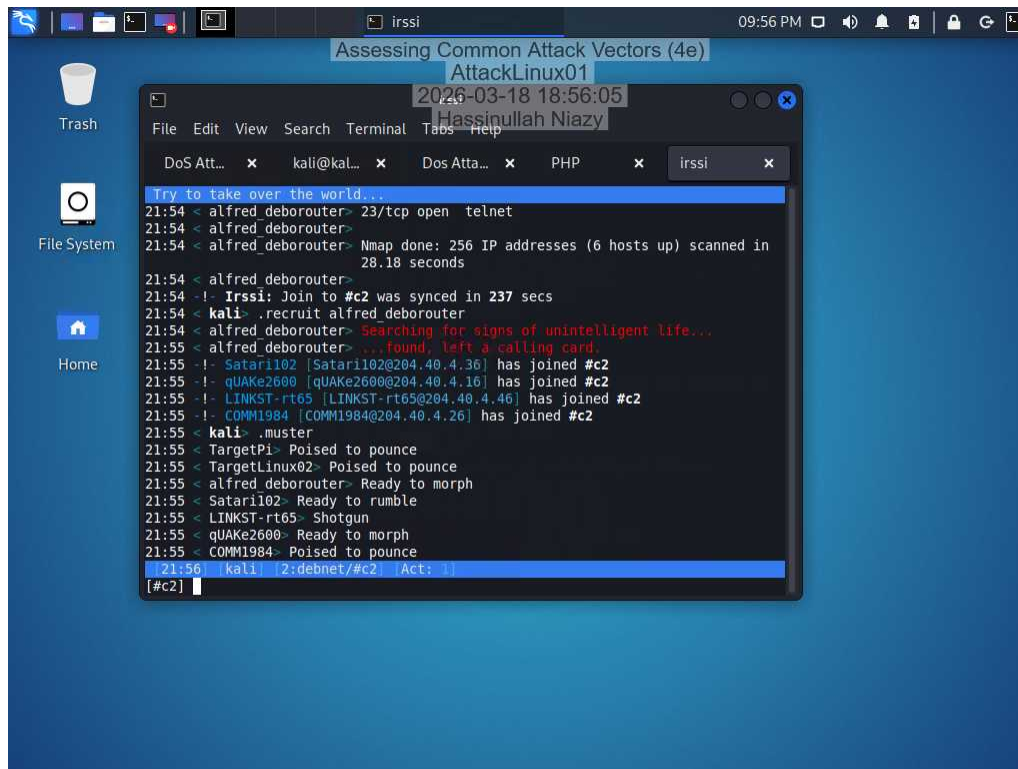
Assessing Common Attack Vectors (4e)

Fundamentals of Information Systems Security, Fourth Edition - Lab 06

Section 2: Applied Learning

Part 1: Perform a Distributed Denial-of-Service Attack

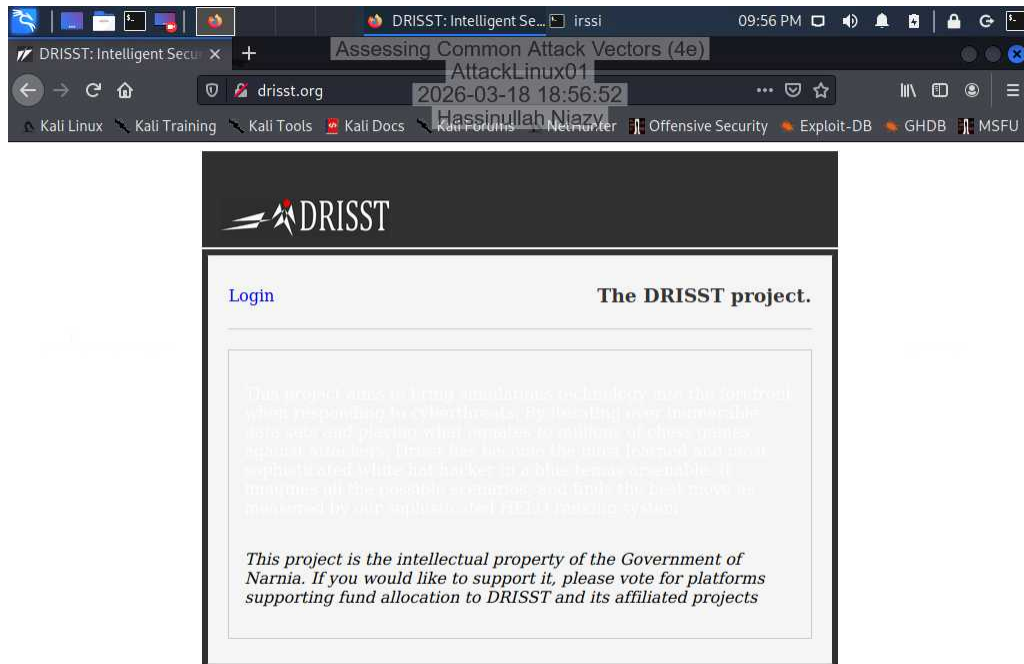
25. Make a screen capture showing the newly recruited hosts.



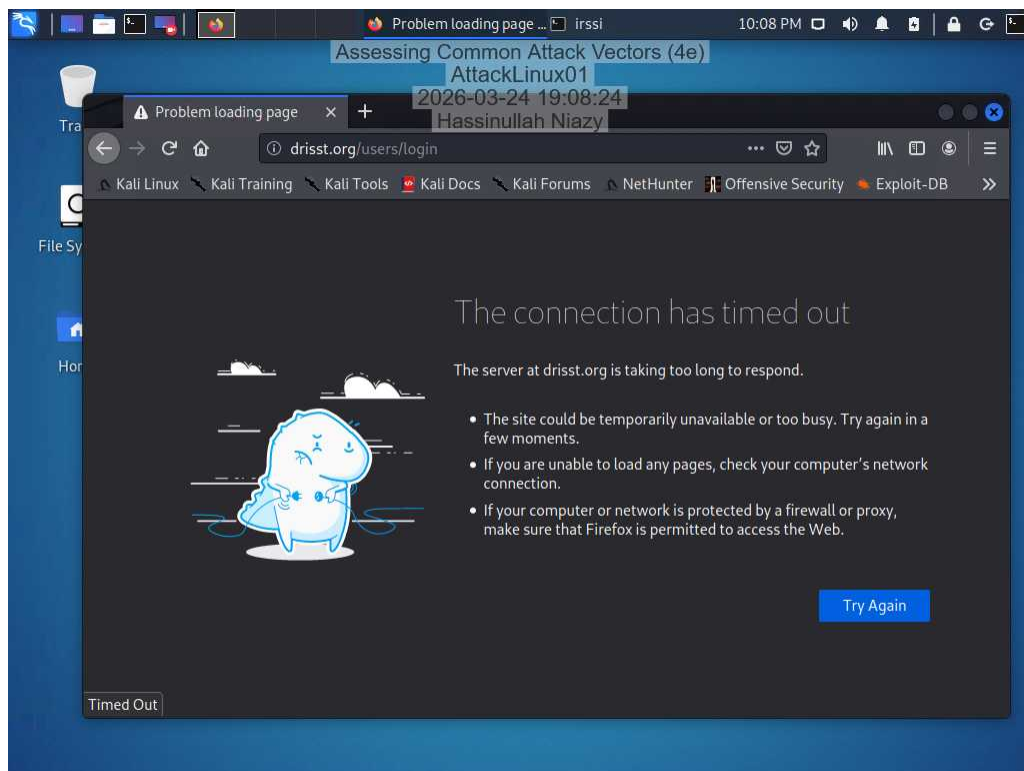
The screenshot shows a Kali Linux desktop environment. A terminal window is open, displaying a DDoS attack in progress. The terminal output shows the following commands and responses:

```
Try to take over the world...
21:54 < alfred deborouter> 23/tcp open telnet
21:54 < alfred deborouter>
21:54 < alfred deborouter> Nmap done: 256 IP addresses (6 hosts up) scanned in
28.18 seconds
21:54 < alfred deborouter>
21:54 < alfred deborouter> Join to #c2 was synced in 237 secs
21:54 < kali> .recruit alfred deborouter
21:54 < alfred deborouter> searching for signs of unintelligent life...
21:55 < alfred deborouter> ...found, left a calling card.
21:55 < kali> Sataril102 [Sataril102@204.40.4.36] has joined #c2
21:55 < kali> qUAKe2600 [qUAKe2600@204.40.4.16] has joined #c2
21:55 < kali> LINKST-rt65 [LINKST-rt65@204.40.4.46] has joined #c2
21:55 < kali> COMM1984 [COMM1984@204.40.4.26] has joined #c2
21:55 < kali> .muster
21:55 < TargetPi> Poised to pounce
21:55 < TargetLinux02> Poised to pounce
21:55 < alfred deborouter> Ready to morph
21:55 < Sataril102> Ready to rumble
21:55 < LINKST-rt65> Shotgun
21:55 < qUAKe2600> Ready to morph
21:55 < COMM1984> Poised to pounce
21:56 < kali> [2:debnet/#c2] Act: 1
[#c2]
```

28. Make a screen capture showing the **drisst.org** webpage.



33. Make a screen capture showing the **failed connection to drisst.org**.



35. Make a screen capture showing the “PF states limit reached” error message.

```
FreeBSD/amd64 (pfSense.home.arp) (ttyv00)
VMware Virtual Machine: Netrate Device ID: 6adad12d13013215c2d5
Assessing Common Attack Vectors (4e)
2026-03-24 19:11:30
Hassinnullah Niaz
*** Welcome to pfSense 2.5.2-RELEASE (amd64) on pfSense ***

WAN (wan)      -> vmx0      -> v4: 201.10.1.1/24
LAN (lan)      -> vmx1      -> v4: 172.31.0.1/24
DMZ (opt1)     -> vmx2      -> v4: 172.31.0.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults    13) Update from console
5) Reboot system              14) Disable Secure Shell (sshd)
6) Halt system                15) Restore recent configuration
7) Ping host                  16) Restart PHP-FPM
8) Shell

Enter an option: [zone: pf states] PF states limit reached
[zone: pf states] PF states limit reached
[zone: pf states] PF states limit reached
[zone: pf states] PF states limit reached
```

Part 2: Perform a Social Engineering Attack

24. Make a screen capture showing the finished SET phishing email composition.

```
root@kali: /home/kali
11:32 PM
Assessing Common Attack Vectors (4e)
AttackLinux01
2026-03-24 20:32:18
Hassinnullah Niaz

File Edit View Search Terminal Help
1. Use a gmail Account for your email attack.
2. Use your own server or open relay

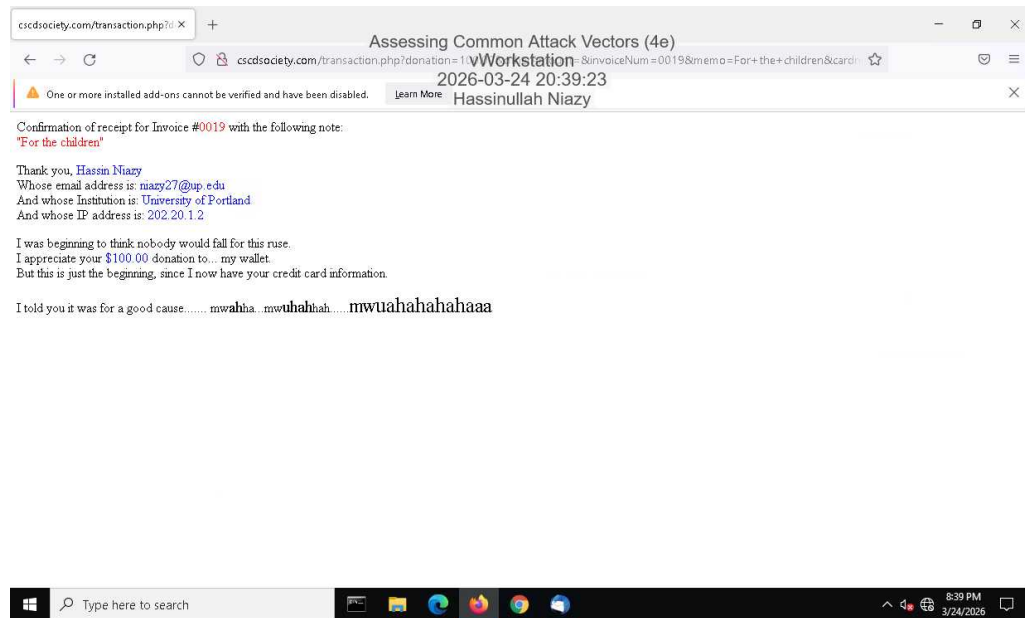
set:phishing>2
set:phishing> From address (ex: moo@example.com):mramone@securelabsondemand.com
set:phishing> The FROM NAME the user will see:Matt Ramone
set:phishing> Username for open-relay [blank]:
Password for open-relay [blank]:
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com):smtp.normailer.com
set:phishing> Port number for the SMTP server [25]:25
set:phishing> Flag this message/s as high priority? [yes/no]:no
Do you want to attach a file - [y/n]: n
Do you want to attach an inline file - [y/n]: n
set:phishing> Email subject:A favor?
set:phishing> Send the message as html or plain? 'h' or 'p' [p]:h
[!] IMPORTANT: When finished, type END (all capital) then hit {return} on a new line.
set:phishing> Enter the body of the message, type END (capitals) when finished:Hey Alice,
Next line of the body:
Next line of the body: Just learned a friend of mine is raffling off a pair of Hamilton tickets next month. All you have to do to enter is making a donation of $58 or more to the Cure Strange Childhood Diseases Society. I know how much you like musicals, charity, and curing strange childhood diseases, and I would really appreciate it if you could support my friend's fundraising efforts. If you'd like to make a donation at the link below, just send me your receipt afterwards and I'll make sure you're entered in the raffle. Thanks!
Next line of the body: <a href="http://cscdsociety.com"> click here </a>
Next line of the body: END
[*] SET has finished sending the emails

Press <return> to continue
```


Assessing Common Attack Vectors (4e)

Fundamentals of Information Systems Security, Fourth Edition - Lab 06

36. Make a screen capture showing the **transaction.php** page in the browser.



Section 3: Challenge and Analysis

Part 1: Recommend Defensive Measures

Identify and **describe** at least two defensive measures that can be used against injection attacks. Be sure to cite your sources.

1: Parameterized Queries by using placeholders ?, stops injecting at the database level.2: Input Validation stops malicious data earlier in the pipeline.

Sources:1: OWASP - SQL Injection prevention Cheat Sheet.2: OWASP - Input Validation Cheat Sheet

Identify and **describe** at least two defensive measures that can be used against malware attacks. Be sure to cite your sources.

1: Anti-virus software detects and block malwares in real time.2: Patch management prevents attackers from exploiting known weaknesses.

Sources: 1: CISA - Malware Prevention Guidance2: CISA - Understanding Patches

Identify and **describe** at least two defensive measures that can be used against denial-of-service attacks. Be sure to cite your sources.

1: Traffic filtering and rate limiting reduce malicious request volume.2: Load balancing and redundancy maintains availability under heavy traffic.

Sources:1: OWASP - DoS Cheat Sheet2: CISA - DDoS Quick Guide

Identify and **describe** at least two defensive measures that can be used against social engineering attacks. Be sure to cite your sources.

1: Security awareness training reduces human susceptibility to manipulate.2: Multi-factor authentication protects accounts even if credentials are compromised.

Sources:CISA

Part 2: Research Additional Attack Vectors

Assessing Common Attack Vectors (4e)

Fundamentals of Information Systems Security, Fourth Edition - Lab 06

Describe the additional attack vector you selected and **identify** at least two defensive measures that can be used against it. Be sure to cite your sources.

Session hijacking is a type of attack where an attacker takes over a valid user session by stealing or predicting a session identifier.

Defense:1: Use Secure Session Management (HTTPS): protects session data in transit and storage.2: Session Expiration and Regeneration: it reduces the usefulness of stolen sessions by regenerating session IDs during critical events.

Source:

1: OWASP